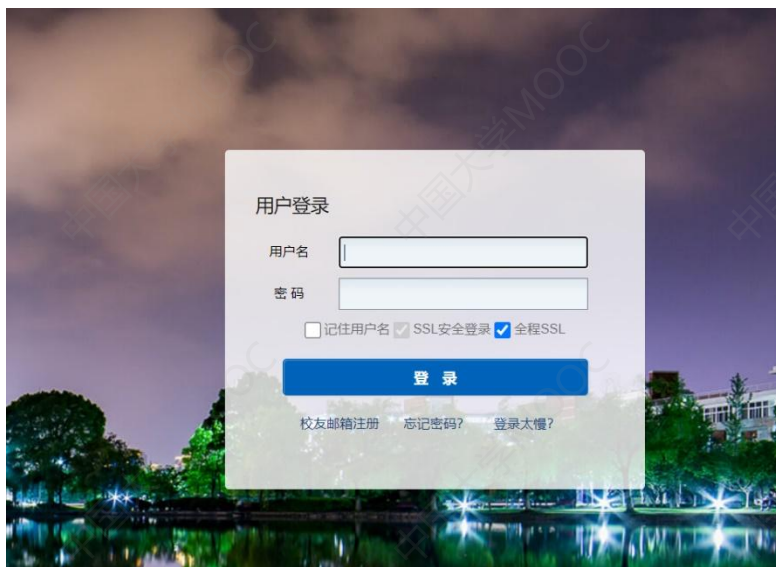


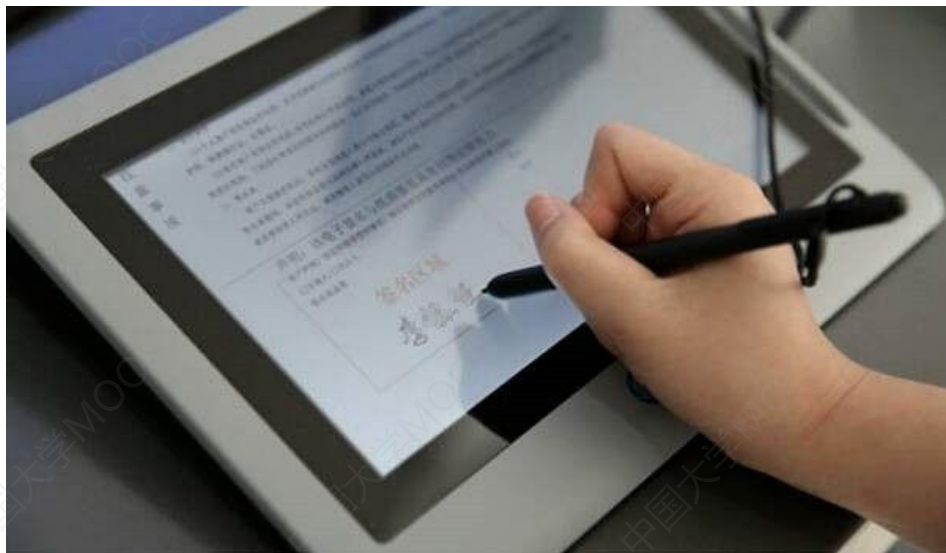
# 认证技术

主讲人：吕秋云

# 网络世界的认证



# 网络世界的认证





# 当前，我们面临严重的安全威胁

# 被动攻击 VS 主动攻击

## 被动攻击

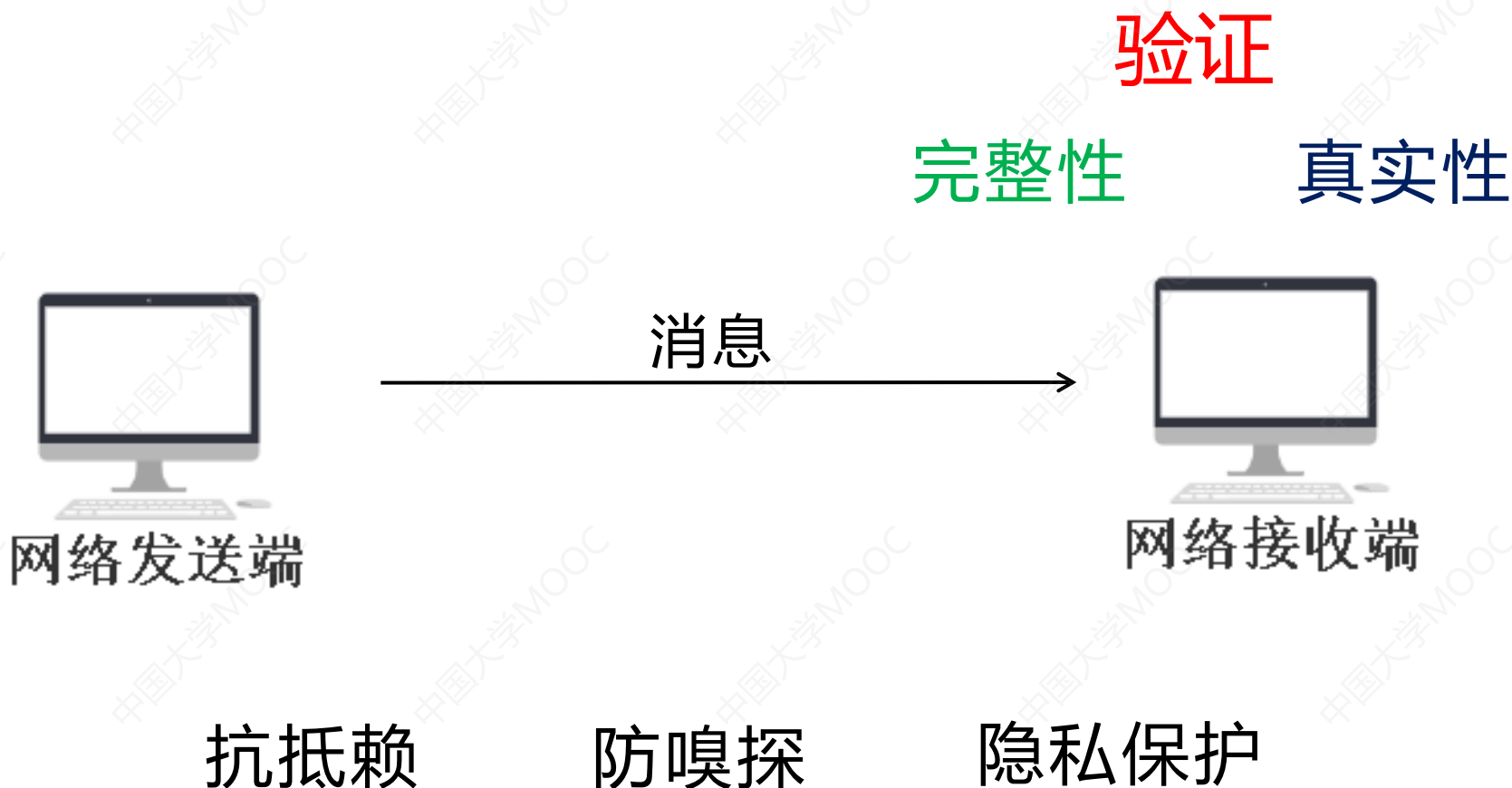
嗅探信息  
盗取数据

## 主动攻击

假冒消息  
篡改消息  
截留消息  
.....



# 认证功能



思考：

如何进行**完整性**检测？



？今天晚上7点钟在7-120教室开班会

**答：**向辅导员确认





# 思路：是否篡改？



## 做比较

把原信息和某一信息进行比较！

比较信息的要求

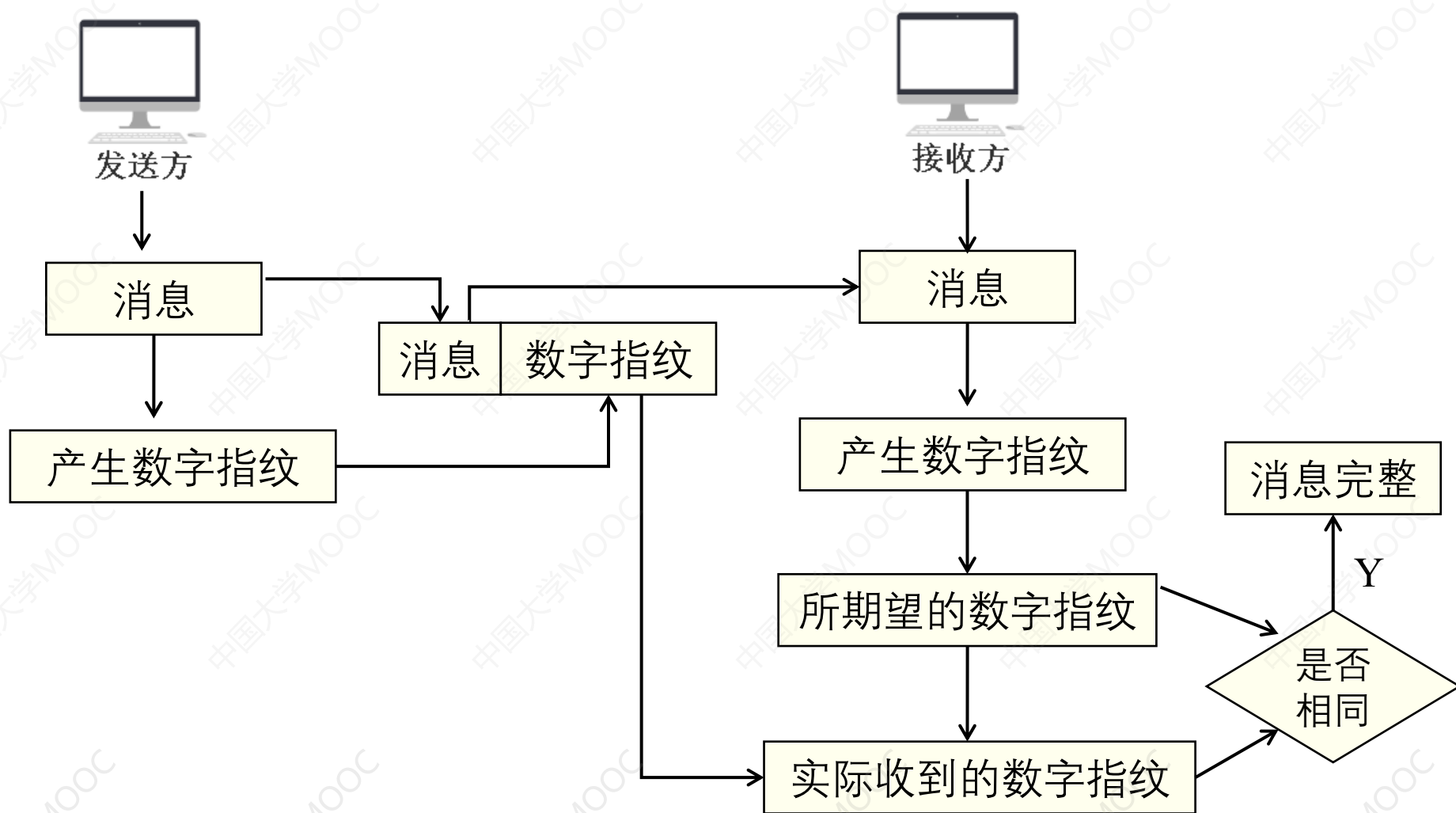


二者之间必须是有**关联**的，并且另外一个信息**黑客很难篡改**，或者**篡改后很难匹配**。

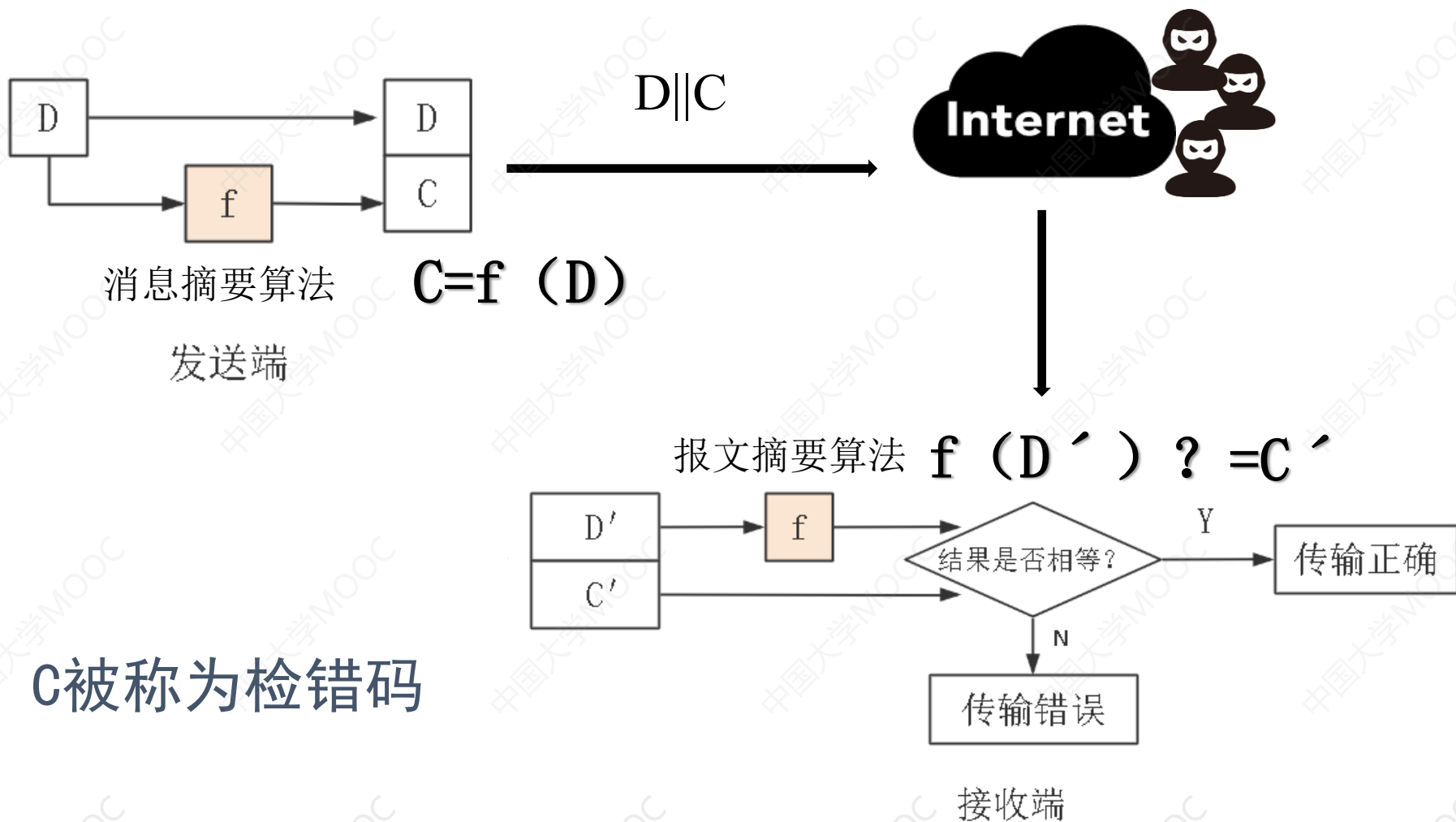
——以此为出发点设计方法或者协议！



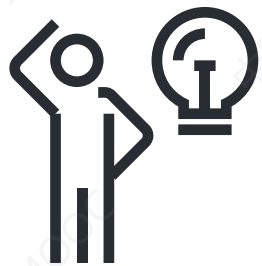
# 消息的完整性检测-流程



# 消息的完整性检测-专业表达



你发现什么安全隐患了吗?



思考：



穷举猜出f

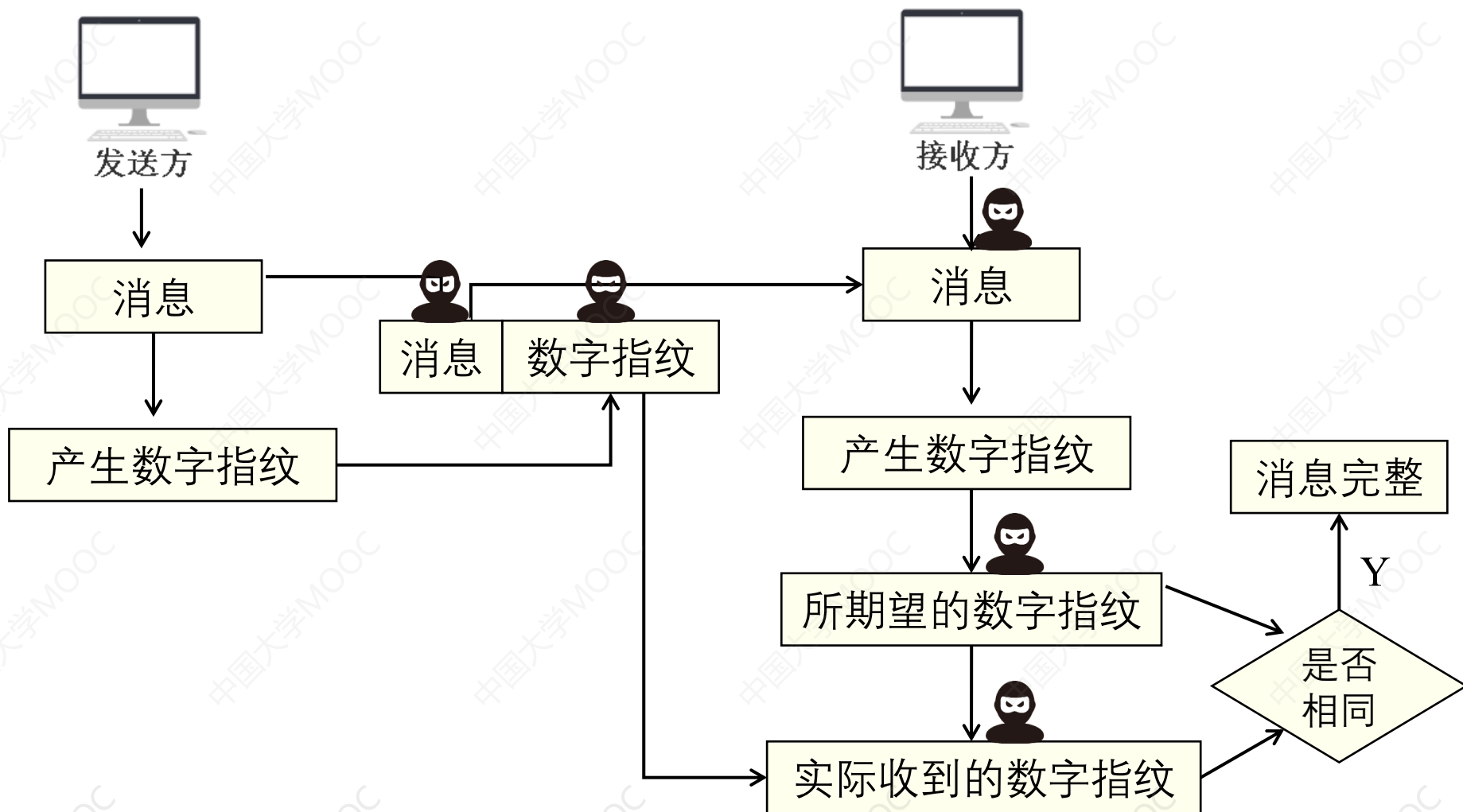
发送方基于函数  $C=f(D)$ ，将C和D一起发向网络，

攻击者将D换成D'，使用f函数形成C'

接受端会判定为？

正确无误

# 消息的完整性检测-潜在的问题

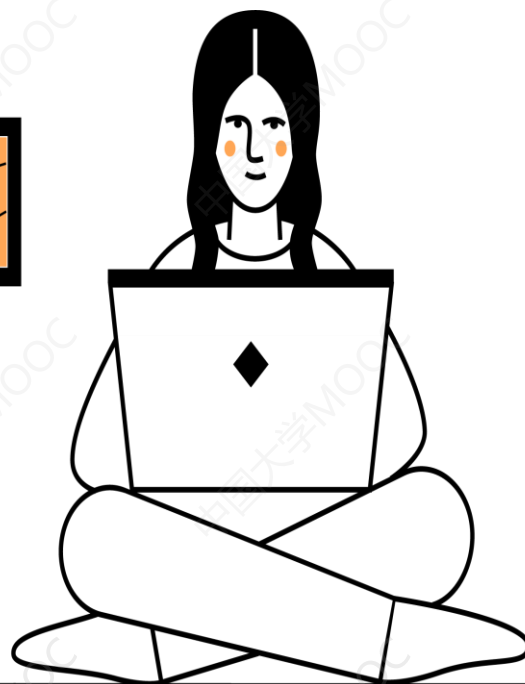


# 可能的解决方案：

阻止攻击者嗅探

阻止攻击者穷举出 $f$

**防止消息伪造**



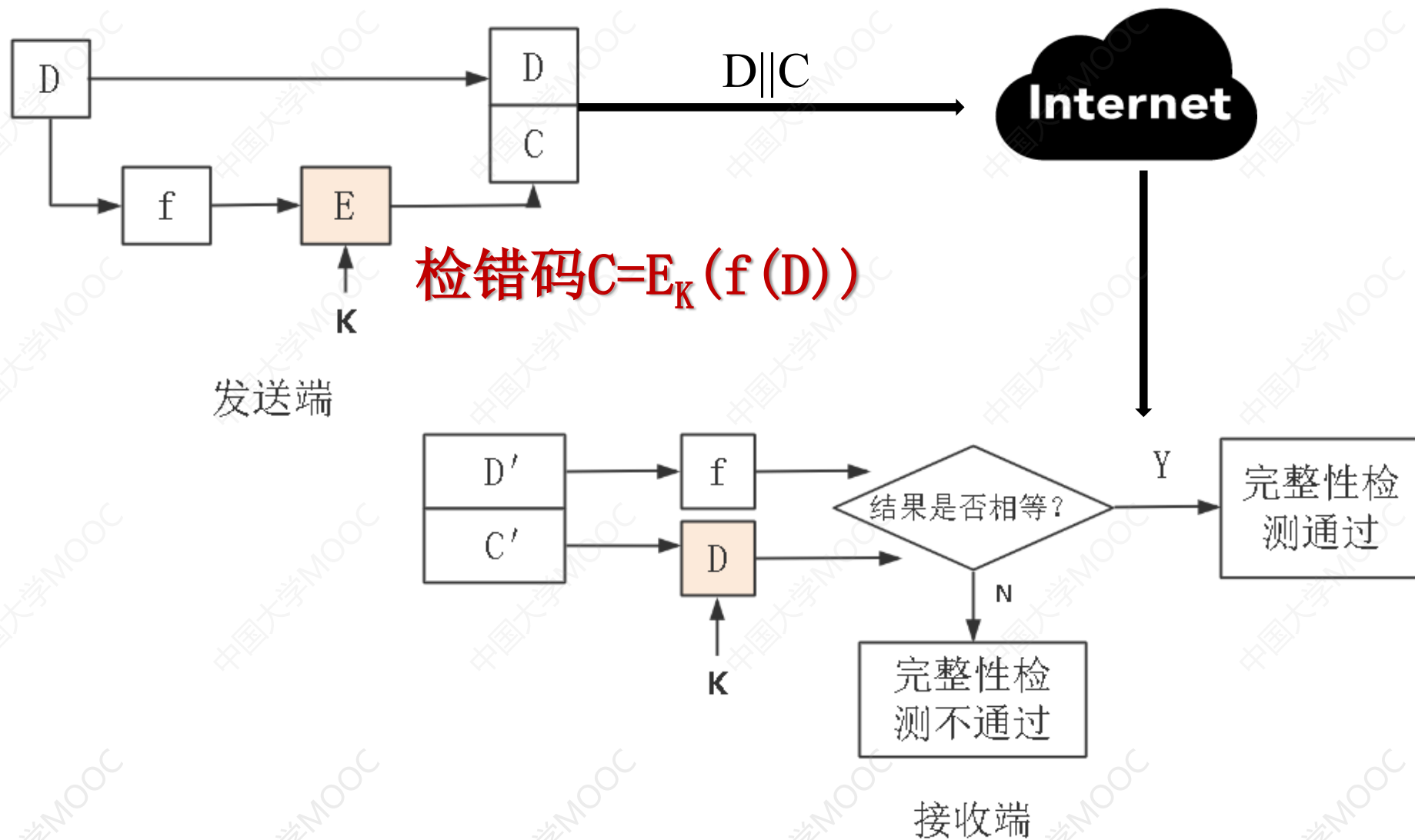
# 思考：

如何进行**完整性**检测的同时**防止消息伪造**？

密码学算法+共享密钥？



# 消息的完整性检测+来源验证





# 消息认证

消息认证=完整性+来源真实性

消息认证码  $MAC = C_k(M)$

**MAC**是在一个**密钥**的控制下将**任意长的消息**映射**到**一个简短的**定长值**，以该值作为认证符，并将它附加在消息后。



## 思考：

## 可否优化？

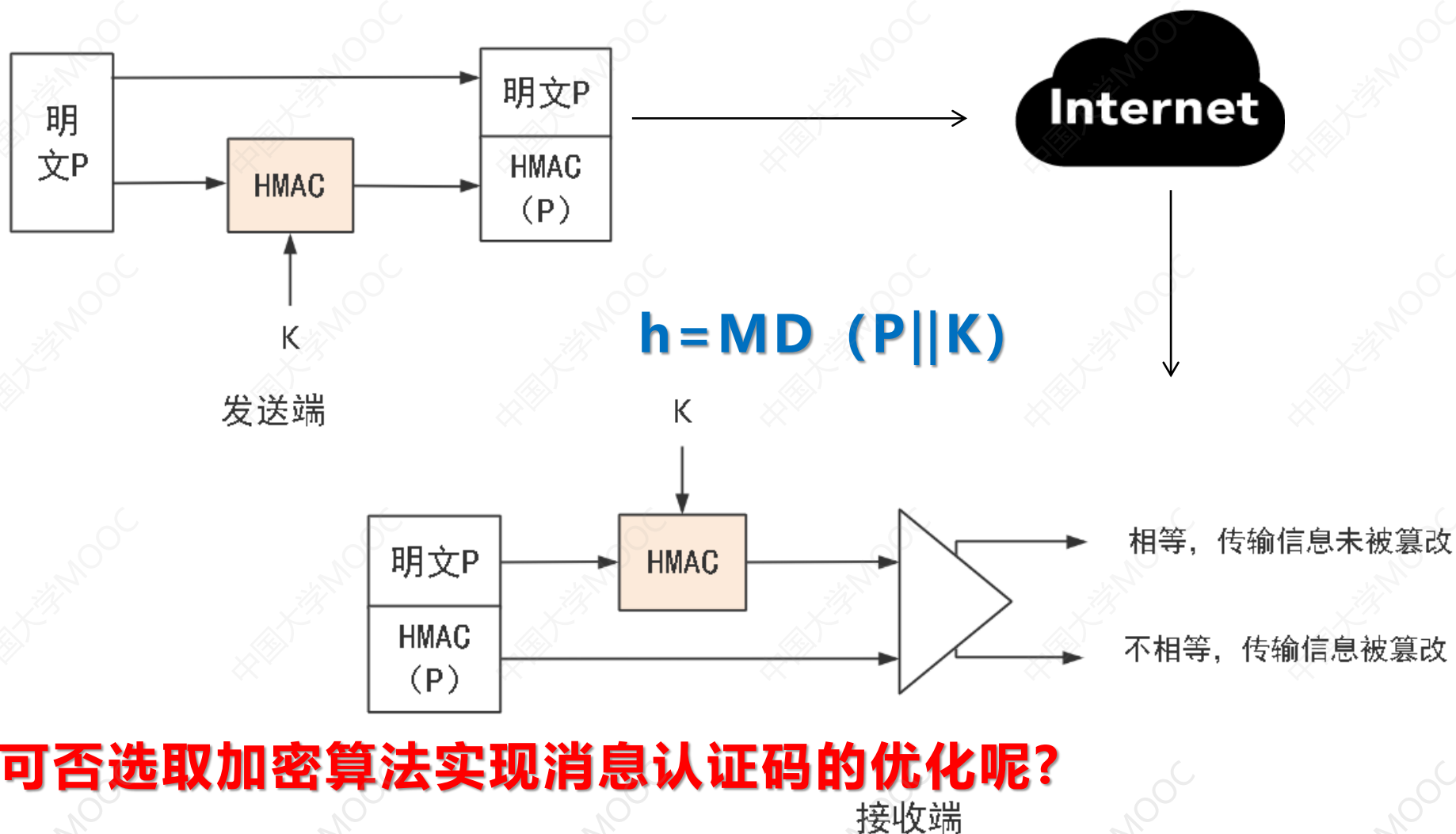
**完整性**和**来源真实性**检测

要求

发送端和接收端完成

**报文摘要**和**加密解密**运算

# 消息认证-HMAC



可否选取加密算法实现消息认证码的优化呢?

# 思考：

当消息认证码MAC应用到**淘宝购物，电子合同签订**等网络应用中时，可能存在什么安全隐患？



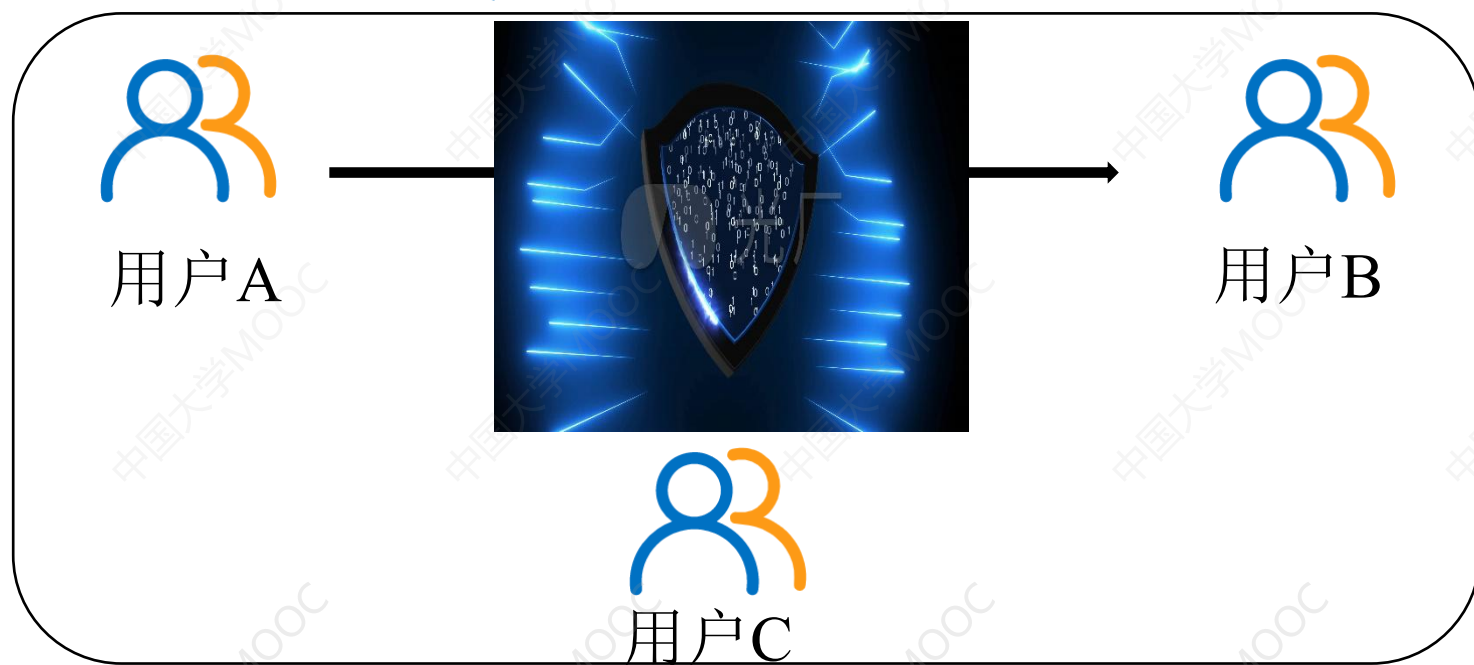
**买卖双方 即为 收发双方**



# 消息认证（码）-能够

消息认证码

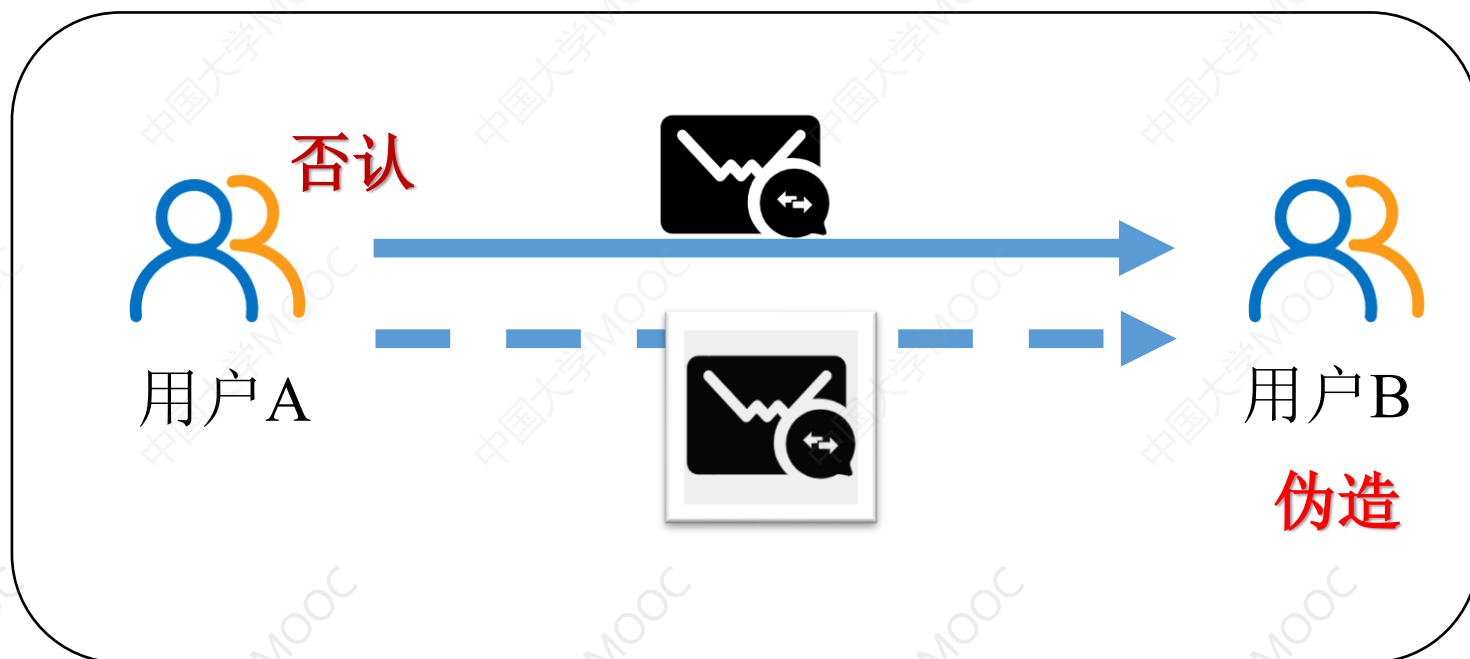
能保护 通信双方之间的数据  
不被第三方攻击



# 消息认证（码）-不能够

## 消息认证**无法保证抗否认性**

消息认证无法防止**通信双方**中的一方对另一方的欺骗，并不保证双方自身的相互**欺骗**。



# 思考：

## 如何实现消息认证后的防抵赖？

**思考：**

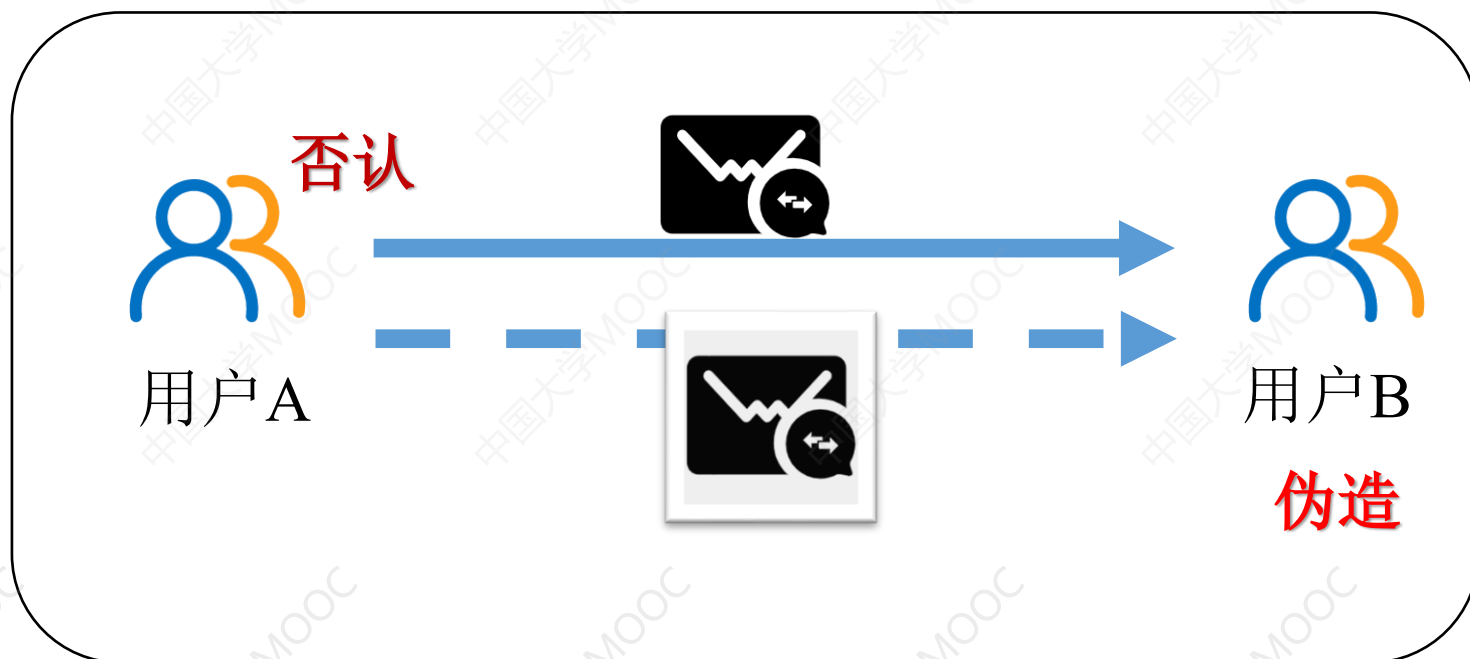
试着应用密码学相关算法来设计防止收发双方的抵赖功能的协议。



# 消息认证（码）-不能够

## 消息认证**无法保证抗否认性**

消息认证无法防止**通信双方**中的一方对另一方的欺骗，并不保证双方自身的相互**欺骗**。



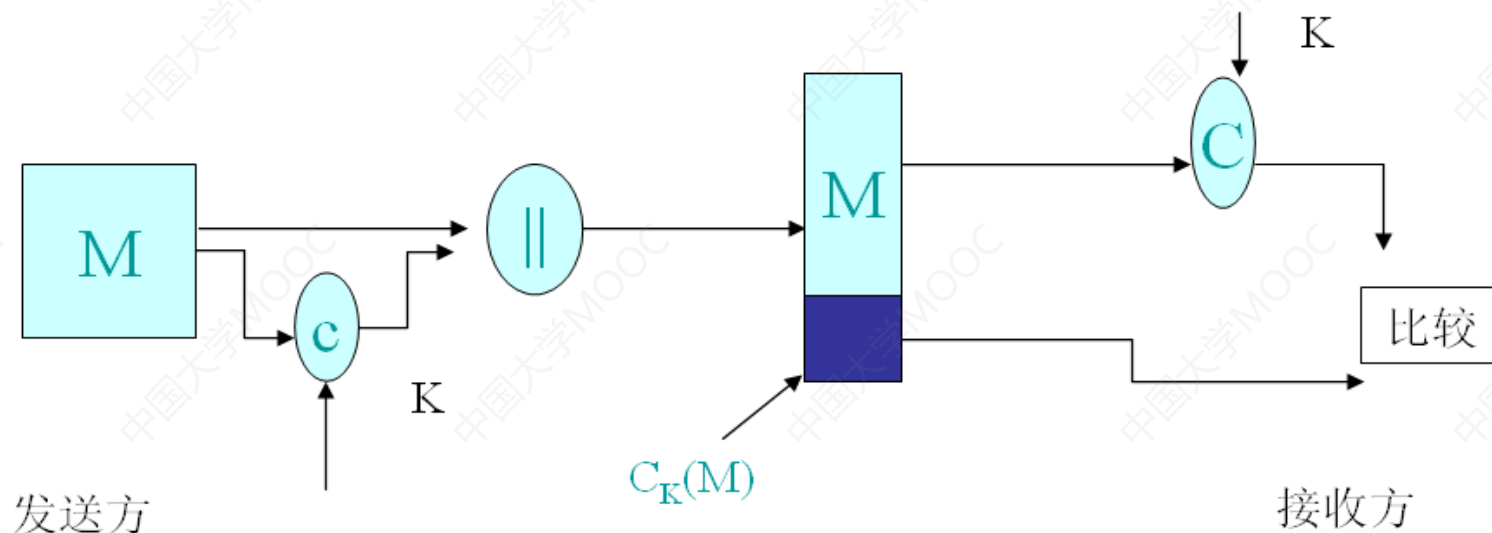


问题3:

如何进行消息认证后的  
防抵赖?

# 消息认证码的基本用途1

## 1. 只提供消息认证，不提供保密性

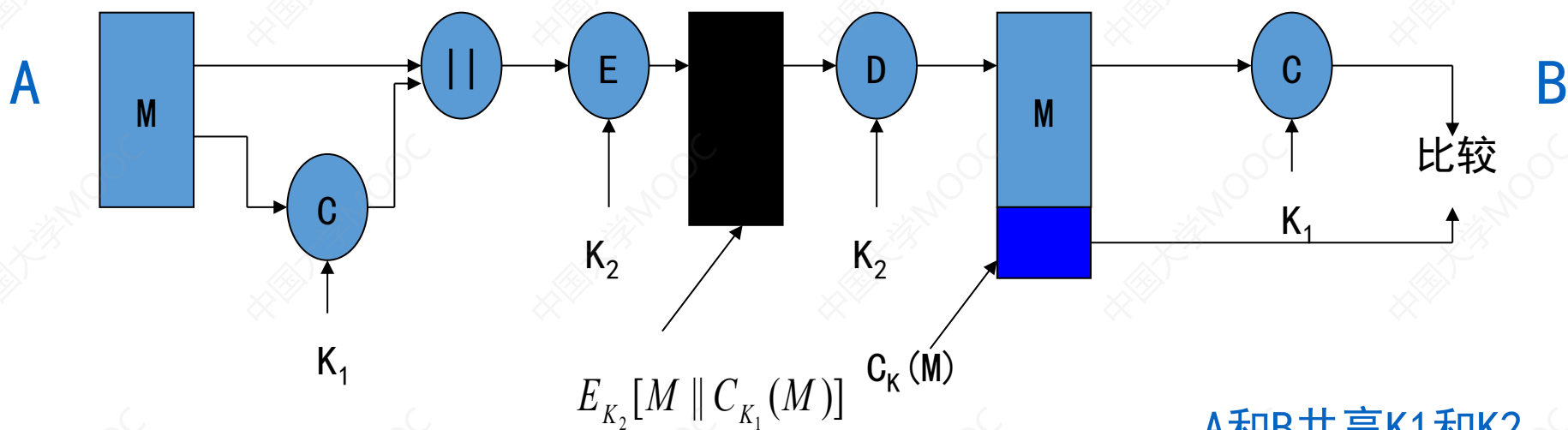


- ❖ 消息认证码MAC:  $MAC = C_k(M)$
- 确认消息未被更改过
  - 确信消息来自于与他共享密钥的发送者

- A和B共享密钥K
- A计算 $MAC = C_k(M)$ ,
- M和MAC一起发送到B
- B对收到的M, 计算MAC, 比较两个MAC是否相同。

# 消息认证码的基本用途2

- 2. 提供消息认证和保密性：与明文有关的认证



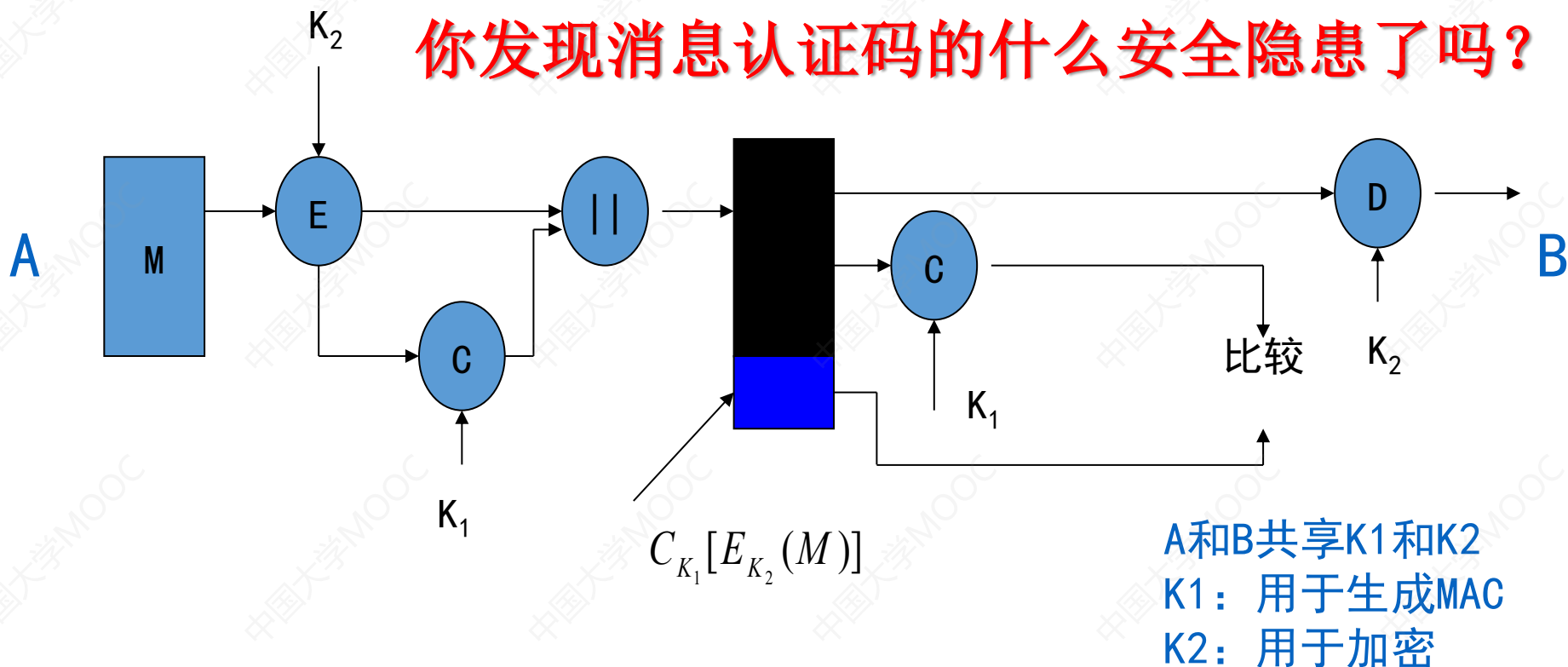
A和B共享K1和K2  
K1：用于生成MAC  
K2：用于加密

- ❖ 发送方发送  $E_{K_2}[M || C_{K_1}(M)]$ 。
- ❖ 该种处理方式除具备(1)的功能外，还具有保密性。

# 消息认证码的基本用途3

- 3. 提供消息认证和保密性：与密文有关的认证

你发现消息认证码的什么安全隐患了吗？



- ❖ 先对消息进行加密，然后再对密文计算MAC，传送 $E_{k_2}(M) || C_{k_1}(E_{k_2}(M))$ 给接收方。
- ❖ 接收方先对收到的密文进行认证，认证成功后，再解密。

# 数字签名

## 消息认证

- ➡ 当收发者之间没有利害冲突时，这对于防止第三者的破坏已经足够了。
  - ➡ 收方能够验证消息发送者身份是否被篡改；
  - ➡ 收方能够验证所发消息内容是否被篡改。

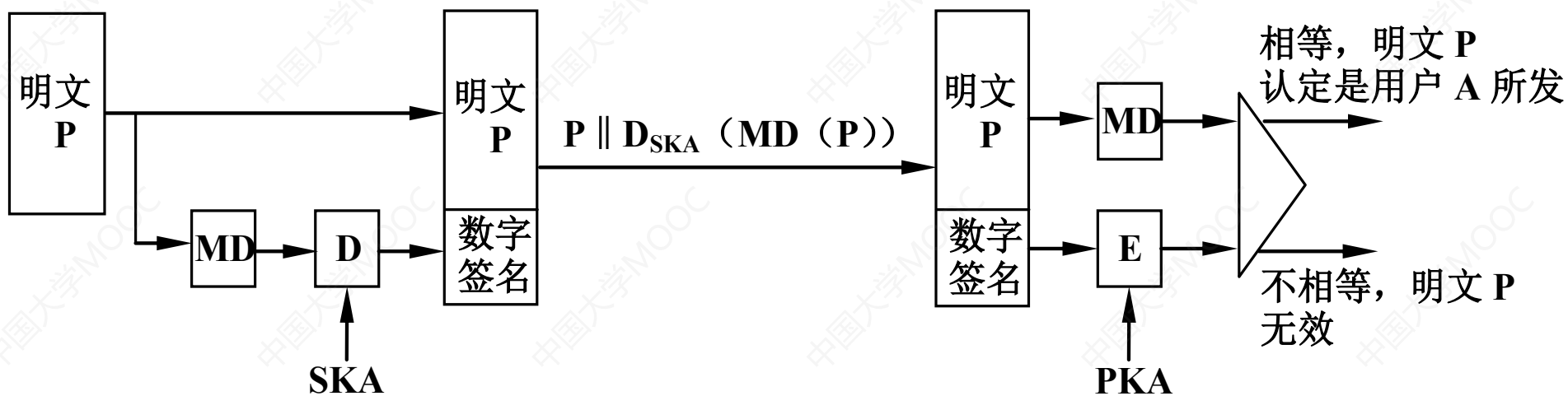
## 数字签名

- ➡ 当收发双方存在利害冲突时，单纯用消息认证技术就无法解决他们之间的纠纷。必须使用数字签名技术。
  - ➡ 数字签名能确定消息来源的真实性
  - ➡ 数字签名能保证实体身份的真实性
  - ➡ 数字签名是不可否认的。

# 数字签名

- 数字签名离不开**公钥密码学**，在公钥密码学中，密钥由公开密钥和私有密钥组成。数字签名包含两个过程：
  - 签名过程：请问使用什么密钥进行签名？
  - 验证过程：请问使用什么密钥进行验证？

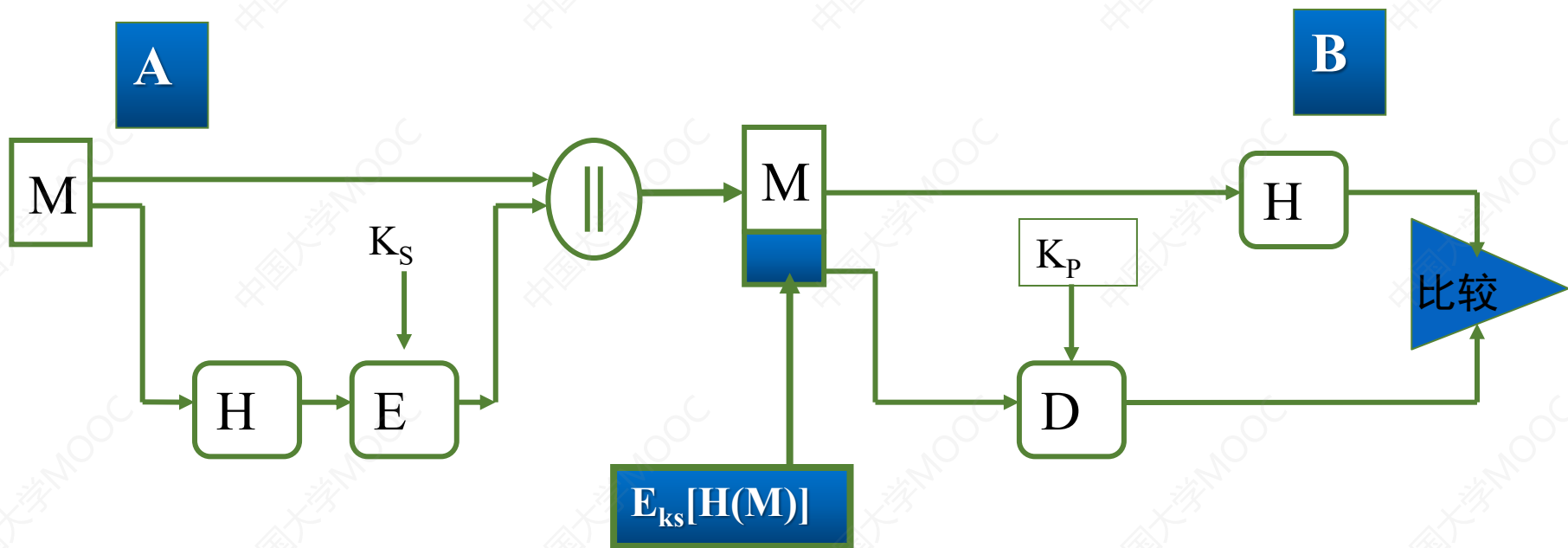
# 数字签名



•规则一： $E_{PKA} (D_{SKA} (P)) = P$ ，通过公钥PKA加密还原的一定是通过私钥SKA解密运算的结果；

•规则二：无法根据报文摘要h，求出报文X，且使得 $MD(X) = h$ ；

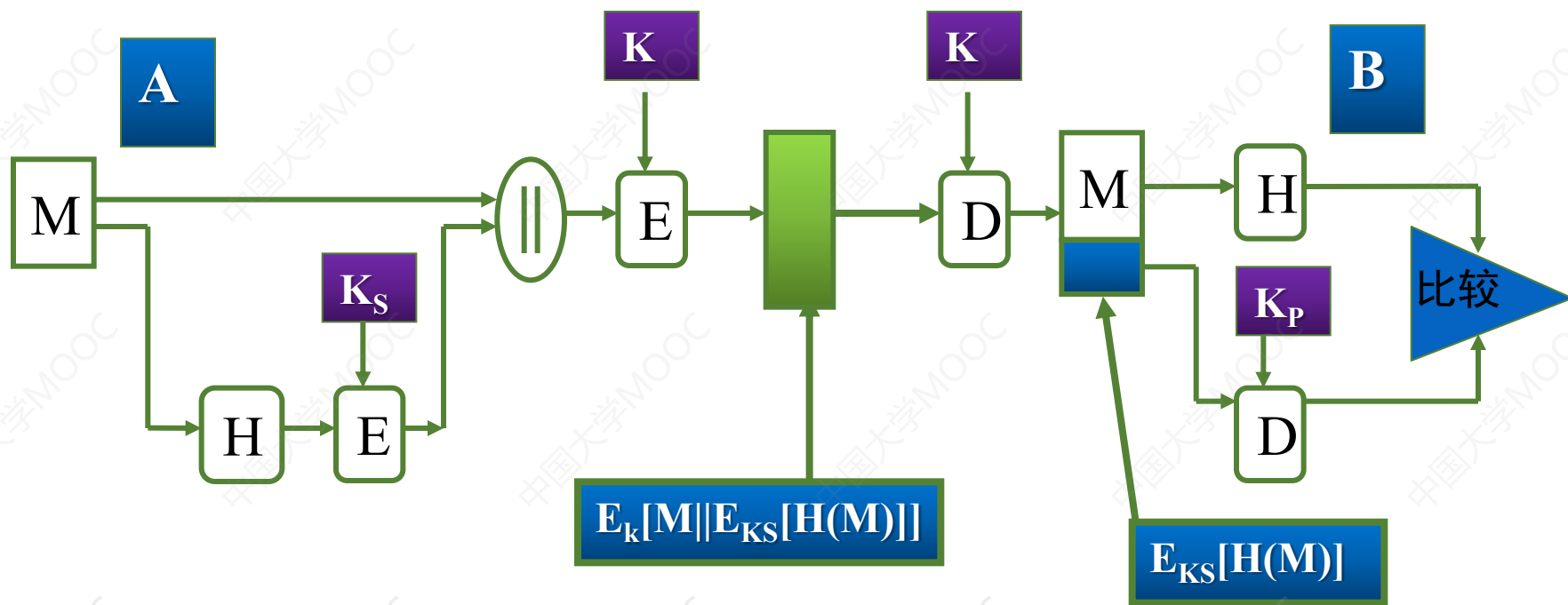
# 数字签名





# 加密/签名结合应用方案

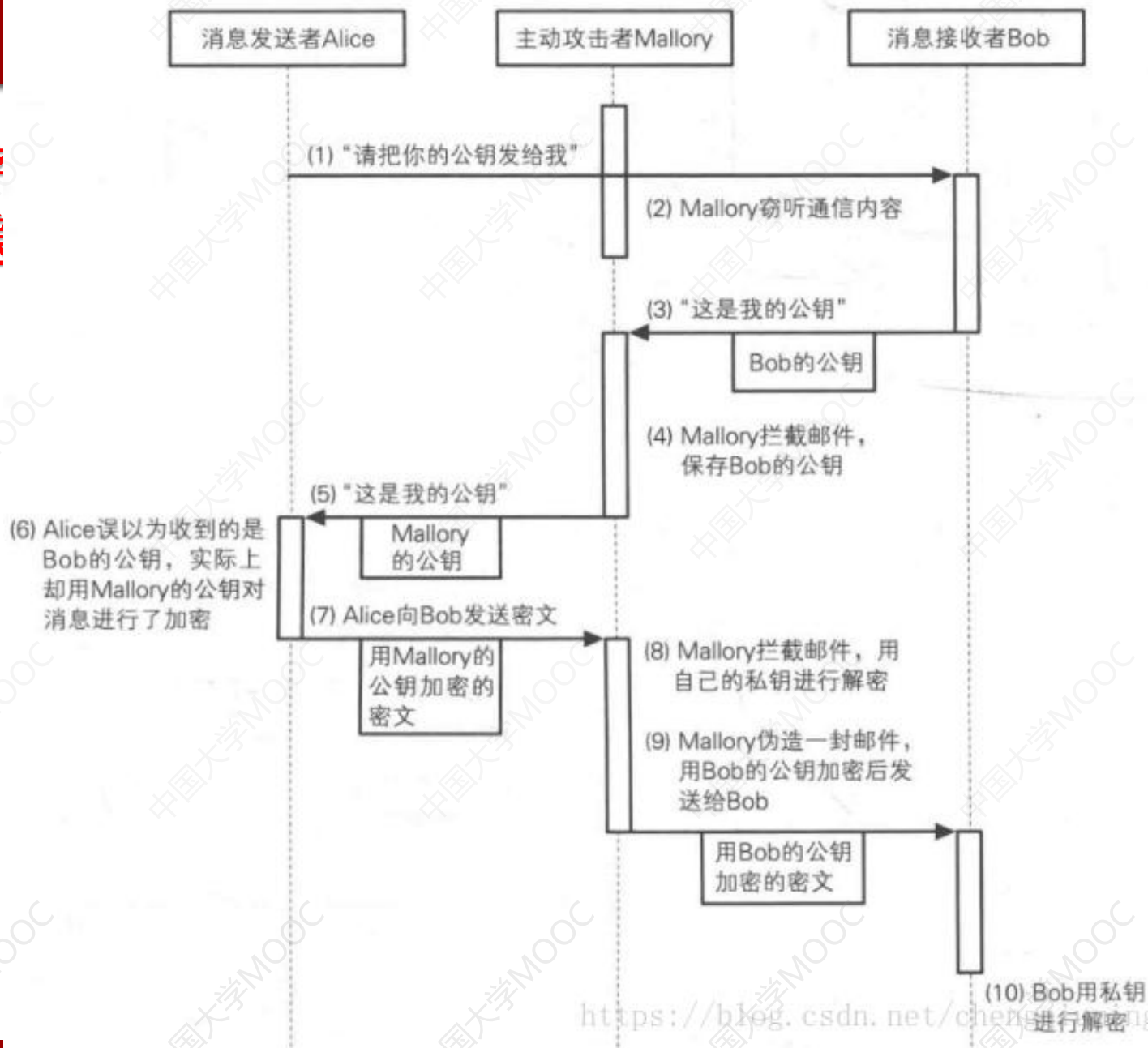
既提供保密性，又提供数字签名



## 思考：

你发现“数字  
在什么安全隐

## 中间人攻击



## 问题4:

用户如何宣告自己的公钥  
确保不遭受中间人攻击?

# PKI

- 怎样分发和获取用户的公钥？
- 如何建立和维护用户与其公钥的对应关系？
- 获得公钥后如何鉴别该公钥的有效性？
- 通信双方如果发生争议如何仲裁？

# PKI

- **公钥基础设施PKI** (Public Key Infrastructure) 的本质是实现大规模网络中的**公钥分发**问题，建立大规模网络中的**信任基础**。
- PKI在实际应用中是一套**软硬件系统**和安全策略的集合，它提供了一整套**安全机制**，使用户在不知道对方身份或分布地点的情况下，以**数字证书**为基础，通过一系列的信任关系进行网络通信和网络交易。

# PKI

## • PKI的组成

- (1) 数字证书（也称作
- (2) 注册授权中心RA
- (3) 认证授权中心CA
- (4) 数字证书库是存储



# PKI

## • 基于PKI的身份认证机制

出示身份标识信息，如用户A的公钥 $K_A$ 、电话号码等

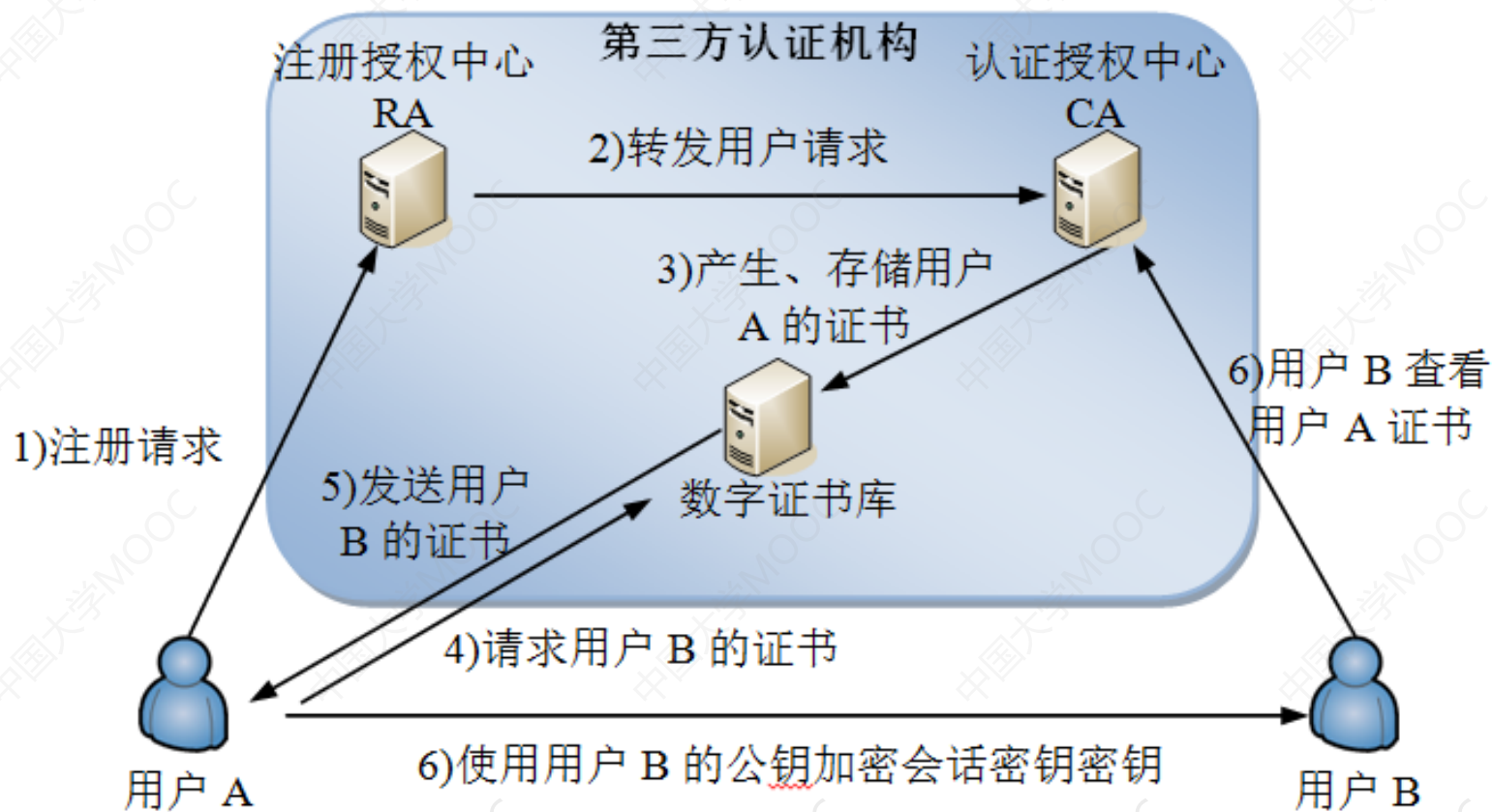
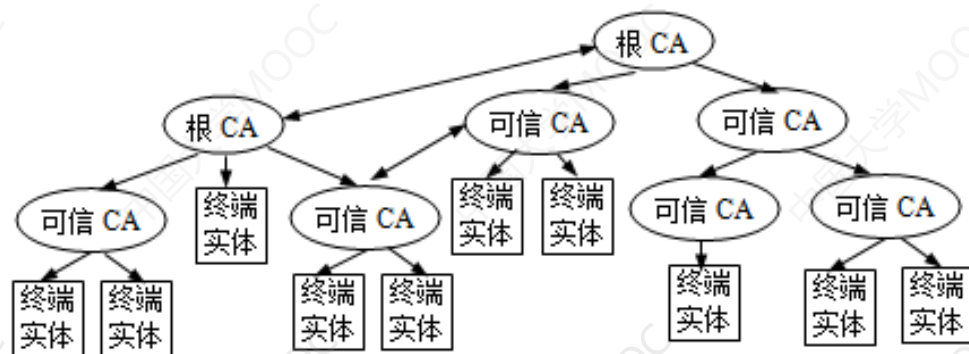
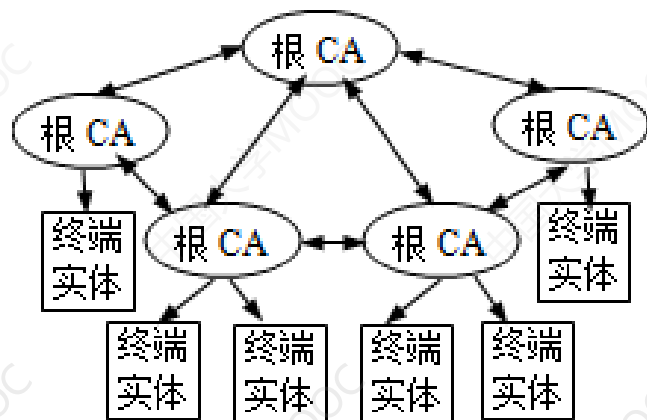
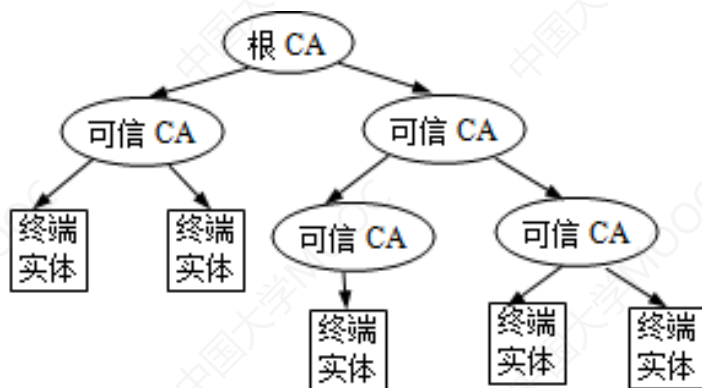


图 4-21 PKI 的基本工作流程图

# PKI

## • 基于PKI的身份认证机制





问题5:

用户在没有公钥证书时，如何证明自己的身份？

# 身份认证

- 基于所知：口令认证
- 基于所有：身份证件，护照，U盾，IC卡
- 基于所生：人脸、指纹、视网膜、步态等生物特征

# 身份认证协议

- Kerberos协议

■ Kerberos 协议：是一种网络认证协议，旨在通过使用对称密钥加密技术在不安全的网络环境中提供强身份验证。它基于“票据”（ticket）机制，用户、服务和认证服务器之间通过交换票据来验证身份。客户机向认证服务器请求票据，认证服务器验证用户身份后发放票据，客户机使用该票据向服务服务器请求服务，服务服务器通过票据验证客户机身份。

- LDAP(轻量级目录访问)协议

- OAuth协议、OpenID协议

- SAML(安全断言标记协议)

# 小结

问题1: 如何进行完整性检测

问题2: 如何进行完整性检测的同时防消息伪造?

问题3: 如何进行消息认证后的防抵赖?

问题4: 用户如何宣告自己的公钥确保不遭受中间人攻击?

问题5: 用户在没有公钥证书时, 如何证明自己的身份?